

Plan de Contingencia y Continuidad del Negocio

Prestador de Servicios de Certificacion (PSC) Goya Ledger

Metadato	Valor
Version	1.0
Fecha de aprobacion	Pendiente
Clasificacion	Confidencial
Responsable	Oficial de Seguridad de la Informacion
Revision programada	Semestral
Ultima revision	—

1. Introduccion y alcance

1.1 Proposito

El presente Plan de Contingencia y Continuidad del Negocio (en adelante, “el Plan”) establece los procedimientos, roles y recursos necesarios para garantizar la continuidad operativa de los servicios de certificacion prestados por Goya Ledger en su calidad de Prestador de Servicios de Certificacion (PSC) conforme a la legislacion chilena vigente.

El Plan tiene por finalidad:

- Minimizar el impacto de interrupciones sobre los servicios criticos de certificacion.
- Asegurar la recuperacion oportuna de los sistemas y datos dentro de los plazos regulatorios.
- Preservar la integridad de la cadena de bloques, los registros de auditoria y los certificados emitidos.
- Cumplir con los requisitos de continuidad establecidos por la normativa aplicable.

1.2 Alcance

Este Plan aplica a la totalidad de la infraestructura tecnologica y los servicios del PSC Goya Ledger, incluyendo:

- **Nodos blockchain:** Nodos completos (Full) que ejecutan el consenso BFT (HotStuff + DPoS) sobre Rust/Actix-Web 4.
- **Autoridad de Certificacion (CA):** Emision, revocacion y gestion del ciclo de vida de certificados digitales.
- **Autoridad de Sellado de Tiempo (TSA):** Servicio de sellado de tiempo conforme a RFC 3161, con serial persistido en disco.
- **Servicio OCSP:** Consulta en linea del estado de revocacion de certificados.
- **Firma electronica:** Servicios de Firma Electronica Simple (FES/Ed25519) y Firma Electronica Avanzada (FEA/ML-DSA-65 con evidencia biometrica).
- **Almacenamiento:** RocksDB con Write-Ahead Log (WAL) y volúmenes Docker persistentes.
- **Red P2P:** Comunicacion entre nodos via TCP/TLS con protocolo push-gossip para propagacion de bloques.
- **Registro de auditoria:** Log con cadena de hashes SHA-256 para verificacion de integridad (hash chain).
- **Infraestructura de despliegue:** Docker Compose multi-nodo, scripts de operacion (`bcctl.sh`, `sandbox.sh`, `sandbox-backup.sh`).
- **Clientes ligeros:** Modo `NODE_MODE=light` como alternativa de operacion degradada.

1.3 Exclusiones

Quedan fuera del alcance de este Plan los servicios auxiliares no criticos tales como el Block Explorer UI, la interfaz de votacion electronica (Cerulean Voto) y los dashboards de observabilidad (Grafana/Prometheus), cuya indisponibilidad no compromete la prestacion de servicios de certificacion.

2. Marco normativo

2.1 Legislacion chilena

Norma	Relevancia
Ley 19.799 sobre Documentos Electronicos, Firma Electronica y Servicios de Certificacion	Marco general del PSC. Art. 12 y siguientes: obligaciones del prestador, incluyendo continuidad del servicio.
Decreto Supremo N.o 181 de 2002 (Reglamento de la Ley 19.799)	Art. 14: requisitos de infraestructura y seguridad del PSC. Art. 22: plan de contingencia obligatorio. Art. 24: respaldos y recuperacion ante desastres.
Ley 21.459 sobre Delitos Informaticos	Obligaciones de reporte y preservacion de evidencia digital ante incidentes de seguridad.
Ley 19.628 sobre Proteccion de la Vida Privada	

Norma	Relevancia
	Proteccion de datos personales contenidos en certificados y registros del PSC.
NCh-ISO 27001:2013	Referencia para el sistema de gestion de seguridad de la informacion (SGSI).

2.2 Normativa internacional

Norma	Relevancia
ETSI EN 319 401 v2.3.1	Clausula 7.11: Requisitos de planificacion de continuidad del negocio para prestadores de servicios de confianza (TSP).
ETSI EN 319 411-1	Politica y practicas de certificacion para certificados web. Requisitos de disponibilidad del servicio.
ETSI EN 319 421	Requisitos de politica para autoridades de sellado de tiempo (TSA). Continuidad del servicio de sellado.
ETSI EN 319 411-2	Requisitos para certificados cualificados.
ISO 22301:2019	Sistema de gestion de continuidad del negocio. Marco metodologico adoptado.
ISO 27031:2011	Directrices para la preparacion de las TIC para la continuidad del negocio.
NIST SP 800-34 Rev. 1	Guia de planificacion de contingencia para sistemas de informacion federales.

2.3 Alineamiento regulatorio

El presente Plan ha sido elaborado de conformidad con el articulo 22 del Decreto 181, que exige al PSC mantener un plan de contingencia que contemple, como minimo:

1. Procedimientos de respaldo periodico de la informacion critica.
2. Mecanismos de recuperacion ante desastres con tiempos definidos.
3. Pruebas periodicas del plan documentadas.
4. Designacion de responsables para cada procedimiento.

Asimismo, cumple con ETSI EN 319 401 clausula 7.11, que requiere:

- Analisis de impacto al negocio (BIA).
- Estrategia de continuidad documentada.
- Planes de recuperacion probados.
- Revision y actualizacion periodica.

3. Analisis de impacto al negocio (BIA)

3.1 Identificacion de servicios criticos

Los servicios del PSC se clasifican en tres niveles de criticidad:

Nivel	Servicio	Descripcion	RTO	RPO
Critico	Autoridad de Certificacion (CA)	Emision y revocacion de certificados	4 horas	0 (sin perdida)
Critico	Autoridad de Sellado de Tiempo (TSA)	Sellado RFC 3161 con serial monotonicamente creciente	4 horas	0 (sin perdida)
Critico	Servicio OCSP	Consulta de estado de revocacion	2 horas	0 (sin perdida)
Critico	Consenso BFT	Ordenamiento y finalizacion de bloques (HotStuff + DPoS)	4 horas	0 (sin perdida)
Alto	Firma electronica (FES/FEA)	Creacion y validacion de firmas	8 horas	1 hora
Alto	Red P2P	Propagacion de bloques via push-gossip TCP/TLS	4 horas	N/A
Alto	Registro de auditoria	Log con cadena de hashes SHA-256	4 horas	0 (sin perdida)
Medio	API REST	Endpoints /api/v1/* para integraciones	8 horas	1 hora
Medio	Cliente ligero	Modo degradado NODE_MODE=light	12 horas	N/A
Bajo	Block Explorer / Dashboards	Visualizacion y monitoreo	24 horas	4 horas

RTO = Recovery Time Objective (tiempo maximo de recuperacion). **RPO** = Recovery Point Objective (perdida maxima de datos tolerada).

3.2 Dependencias criticas

Consenso BFT (HotStuff + DPoS)

```
|
|-- RocksDB (almacenamiento de bloques, WAL)
|   |
|   |-- Volumen Docker persistente (sandbox-data)
|   |-- Sistema de archivos del host
|
```

```

+-- Red P2P (TCP/TLS push-gossip)
|
|   +-- Certificados TLS (TLS_CERT_PATH / TLS_KEY_PATH)
|   +-- Conectividad de red entre nodos
|
+-- Modulo criptografico (crates/pqc_crypto_module/)
|
|   +-- Ed25519 (FES)
|   +-- ML-DSA-65 (FEA)
|   +-- SHA-256 (hashing, audit chain)

```

CA / TSA / OCSP

```

|
+-- Claves privadas del PSC
+-- RocksDB (certificados, CRL, serial TSA)
+-- Modulo criptografico

```

3.3 Escenarios de riesgo

ID	Escenario	Probabilidad	Impacto	Riesgo
R-01	Falla de hardware en nodo principal	Media	Critico	Alto
R-02	Corrupcion de base de datos RocksDB	Baja	Critico	Alto
R-03	Perdida de conectividad de red entre nodos	Media	Alto	Alto
R-04	Compromiso de claves privadas del PSC	Muy baja	Critico	Alto
R-05	Falla simultanea de multiples nodos (perdida de quorum BFT)	Baja	Critico	Alto
R-06	Ataque de denegacion de servicio (DDoS)	Media	Alto	Medio
R-07	Corrupcion del serial TSA	Muy baja	Critico	Medio
R-08	Falla del contenedor Docker	Media	Medio	Medio

ID	Escenario	Probabilidad	Impacto	Riesgo
R-09	Error en actualizacion de software	Media	Alto	Medio
R-10	Desastre natural (terremoto, incendio, inundacion)	Baja	Critico	Alto
R-11	Falla electrica prolongada	Media	Alto	Medio
R-12	Rotura de la cadena de hashes del registro de auditoria	Baja	Critico	Alto

4. Estrategias de continuidad

4.1 Alta disponibilidad mediante consenso BFT

La arquitectura de Goya Ledger provee tolerancia a fallas bizantinas de forma nativa:

- **Tolerancia:** El consenso HotStuff tolera hasta f nodos bizantinos donde $n \geq 3f + 1$. En un despliegue de 3 nodos peer + 1 orderer, el sistema tolera 1 falla.
- **Quorum:** Las operaciones de escritura requieren quorum de $2f + 1$ nodos. La perdida de quorum detiene la finalizacion de bloques pero no corrompe el estado existente.
- **Propagacion:** El protocolo push-gossip asegura que los bloques finalizados se repliquen a todos los nodos activos.
- **Recuperacion automatica:** Un nodo que se reincorpora a la red sincroniza automaticamente los bloques faltantes desde los peers.

4.2 Redundancia de almacenamiento

Capa	Mecanismo	Descripcion
WAL (Write-Ahead Log)	<code>flush_wal()</code> de RocksDB	Garantiza que las escrituras pendientes se persistan a disco antes de confirmar. Invocado explicitamente en operaciones criticas.
Volumenes Docker	<code>sandbox-data volume</code>	Datos de RocksDB persistidos en volumen Docker nombrado,

Capa	Mecanismo	Descripcion
Replicacion por consenso	Push-gossip BFT	independiente del ciclo de vida del contenedor. Cada bloque finalizado se replica a todos los nodos del cluster. Redundancia inherente n-fold.
Backup periodico	scripts/sandbox-backup.sh	Crea tarball comprimido del volumen de datos con timestamp. Restauracion via sandbox-backup.sh restore <tarball>.

4.3 Modo de operacion degradada

Ante la indisponibilidad del cluster completo, se dispone de las siguientes estrategias de degradacion controlada:

1. **Operacion con quorum minimo:** Si se pierden nodos pero se mantiene quorum ($2f + 1$), el servicio continua con normalidad. Los nodos caidos se restauran posteriormente.
2. **Modo cliente ligero (NODE_MODE=light):** Permite levantar un nodo que:
 - Opera con rutas de nivel starter unicamente.
 - Proxear escrituras al nodo semilla (SEED_NODE_URL).
 - Mantiene un LocalIdentityStore con DIDs persistidos en JSON en GOYA_DATA_DIR (por defecto ~/ .goya/).
 - **Limitacion:** No puede crear firmas FEA (Firma Electronica Avanzada).
3. **Nodo unico de emergencia:** Despliegue de un unico nodo con NODE_ROLE=peer_and_orderer que opera sin consenso distribuido para mantener servicios CA, TSA y OSCP mientras se restaura el cluster.

4.4 Proteccion de claves criptograficas

- Las claves privadas del PSC se almacenan separadas de los datos operativos.
- El modulo criptografico (crates/pqc_crypto_module/) encapsula todas las operaciones de firma (Ed25519, ML-DSA-65) y hashing (SHA-256).
- En produccion (RUST_BC_ENV=production), se requiere TLS_CERT_PATH y TLS_KEY_PATH.
- Las billeteras de identidad se almacenan como JSON cifrado (DID como clave, JSON de billetera cifrado como valor).
- El secreto de recuperacion del vault (VAULT_RECOVERY_SECRET) se custodia conforme al procedimiento de gestion de secretos.

5. Plan de recuperacion ante desastres (DRP)

5.1 Niveles de activacion

Nivel	Descripcion	Criterio de activacion	Autoridad
Nivel 1	Incidente menor	Falla de un nodo individual, servicio degradado pero operativo	Administrador de sistemas
Nivel 2	Incidente mayor	Perdida de quorum BFT, servicio de certificacion interrumpido	Oficial de Seguridad
Nivel 3	Desastre	Perdida total de infraestructura, compromiso de claves	Director del PSC

5.2 Procedimiento de recuperacion Nivel 1 — Falla de nodo individual

Tiempo estimado de recuperacion: 30 minutos a 2 horas.

1. Diagnosticar el estado del cluster

```
./scripts/bcctl.sh status
```

2. Verificar salud de los nodos restantes

```
curl -sk https://localhost:8080/api/v1/health
```

```
curl -sk https://localhost:8082/api/v1/health
```

```
curl -sk https://localhost:8084/api/v1/health
```

3. Reiniciar el contenedor del nodo afectado

```
docker compose restart node2
```

4. Verificar reincorporacion al cluster

```
./scripts/bcctl.sh status
```

5. Confirmar sincronizacion de bloques

El nodo reincorporado sincroniza automaticamente via push-gossip

6. Ejecutar pruebas de verificacion

```
./scripts/e2e-test.sh
```

Si el reinicio no resuelve el problema:

Opcion A: Recrear el contenedor preservando el volumen

```
docker compose up -d --force-recreate node2
```

```
# Opcion B: Si el volumen esta corrupto, restaurar desde backup
./scripts/sandbox-backup.sh restore backups/cerulean-sandbox-
YYYYMMDD-HHMMSS.tar.gz
./scripts/sandbox.sh
```

5.3 Procedimiento de recuperacion Nivel 2 — Perdida de quorum

Tiempo estimado de recuperacion: 2 a 4 horas.

```
# 1. Evaluar cuantos nodos estan operativos
for port in 8080 8082 8084 8086; do
    echo "Puerto $port: $(curl -sk --max-time 5 https://localhost:
$port/api/v1/health || echo 'INACCESIBLE')"
done

# 2. Si se dispone de al menos un nodo sano, iniciar nodo de
    emergencia
# con rol combinado peer_and_orderer para restaurar servicio
    minimo
docker run -d \
    -e NODE_ROLE=peer_and_orderer \
    -e STORAGE_BACKEND=rocksdb \
    -e STORAGE_PATH=/app/data/rocksdb \
    -e ACL_MODE=enforced \
    -e SIGNING_ALGORITHM=ml-dsa-65 \
    -e RUST_BC_ENV=production \
    -e TLS_CERT_PATH=/app/certs/cert.pem \
    -e TLS_KEY_PATH=/app/certs/key.pem \
    -v emergency-data:/app/data \
    -p 8080:8080 \
    goya-ledger:latest

# 3. Restaurar datos desde el ultimo backup disponible
./scripts/sandbox-backup.sh restore backups/cerulean-sandbox-
YYYYMMDD-HHMMSS.tar.gz

# 4. Verificar integridad del registro de auditoria
# (La cadena de hashes SHA-256 permite detectar manipulacion)
curl -sk https://localhost:8080/api/v1/audit/verify

# 5. Verificar integridad del serial TSA
# (El serial debe ser monotonicamente creciente; verificar que
# no se haya retrocedido tras la restauracion)

# 6. Restaurar nodos adicionales progresivamente
# Los nuevos nodos sincronizaran via push-gossip

# 7. Validar operacion completa del cluster
./scripts/e2e-test.sh # 71 aserciones E2E
```

5.4 Procedimiento de recuperacion Nivel 3 — Desastre total

Tiempo estimado de recuperacion: 4 a 24 horas.

Fase 1: Activacion del sitio alternativo (0-2 horas)

1. Notificar al equipo de respuesta segun el Plan de Comunicaciones (seccion 7).
2. Activar la infraestructura en el sitio alternativo o proveedor cloud alternativo.
3. Restaurar la imagen Docker de Goya Ledger desde el registro de contenedores.

Fase 2: Restauracion de datos (2-6 horas)

1. Crear volúmenes en la nueva infraestructura

```
docker volume create sandbox-data
```

2. Restaurar desde el backup offsite mas reciente

```
./scripts/sandbox-backup.sh restore /path/to/offsite-backup.tar.gz
```

3. Restaurar claves criptograficas desde custodia segura

- Claves TLS del nodo

- Claves de firma del PSC (Ed25519 / ML-DSA-65)

- VAULT_RECOVERY_SECRET

Estas claves NO forman parte del backup de datos RocksDB

y se custodian por separado.

4. Configurar variables de entorno de produccion

```
export RUST_BC_ENV=production
```

```
export TLS_CERT_PATH=/path/to/restored/cert.pem
```

```
export TLS_KEY_PATH=/path/to/restored/key.pem
```

```
export STORAGE_BACKEND=rocksdb
```

```
export ACL_MODE=enforced
```

Fase 3: Verificacion y puesta en servicio (6-12 horas)

1. Levantar cluster con configuracion de produccion

```
docker compose up -d
```

2. Verificar salud de todos los nodos

```
./scripts/bcctl.sh status
```

3. Verificar integridad de la cadena de bloques

Cada bloque referencia el hash del bloque anterior;

la verificacion recorre la cadena completa.

4. Verificar integridad del registro de auditoria

La cadena de hashes SHA-256 (previous_hash -> entry_hash)

debe ser consistente en toda la secuencia.

5. Verificar continuidad del serial TSA

*# El serial debe ser estrictamente mayor que el ultimo emitido
antes del desastre. Si hay duda, avanzar el serial
manualmente.*

```
# 6. Ejecutar suite completa de pruebas
./scripts/e2e-test.sh           # 71 aserciones E2E
./scripts/recovery-test.sh      # Pruebas de recuperacion

# 7. Verificar servicios criticos individualmente
#   - Emision de certificado de prueba
#   - Solicitud de sellado de tiempo
#   - Consulta OCSP
#   - Creacion de firma FES y FEA
```

Fase 4: Normalizacion (12-24 horas)

1. Restaurar nodos adicionales para alcanzar la configuracion nominal del cluster.
2. Reconfigurar DNS y balanceadores de carga hacia la nueva infraestructura.
3. Notificar a los suscriptores y partes confiantes la restauracion del servicio.
4. Documentar el incidente en el registro de auditoria.

5.5 Procedimiento de compromiso de claves privadas

Este escenario requiere accion inmediata conforme al articulo 12 de la Ley 19.799:

1. **Revocar inmediatamente** todos los certificados firmados con la clave comprometida.
2. **Suspender** la emision de nuevos certificados.
3. **Notificar** a la Subsecretaria de Economia (entidad acreditadora) dentro de las 24 horas.
4. **Notificar** a todos los suscriptores de certificados afectados.
5. **Generar** nuevo par de claves en un entorno seguro y auditado.
6. **Re-emitir** certificados con la nueva clave.
7. **Actualizar** la CRL (Certificate Revocation List) y los respondedores OCSP.
8. **Documentar** el incidente completo en el registro de auditoria.

6. Procedimientos de respaldo y restauracion

6.1 Politica de respaldos

Tipo de respaldo	Frecuencia	Retencion	Ubicacion	Mecanismo
Backup completo RocksDB	Diario	30 dias	Sitio primario + offsite	scripts/sandbox-backup.sh
Backup incremental WAL	Cada 4 horas	7 dias	Sitio primario	Copia de archivos WAL de RocksDB
	Tras cada rotacion	Indefinida		Manual, cifrado

Tipo de respaldo	Frecuencia	Retencion	Ubicacion	Mecanismo
Backup de claves criptograficas			Custodia segura offsite (HSM o caja fuerte)	
Backup de configuracion	Tras cada cambio	90 dias	Repositorio Git	Versionado en codigo
Copia de registro de auditoria	Diario	10 anios (art. 24 D.S. 181)	Almacenamiento offsite inmutable	Export CSV + hash de verificacion

6.2 Procedimiento de backup

Backup automatizado diario

```
#!/bin/bash
# /etc/cron.d/goya-backup (ejecutar como root o usuario docker)
# 0 2 * * * /opt/goya-ledger/scripts/backup-diario.sh

set -euo pipefail
BACKUP_DIR="/backups/goya-ledger"
RETENTION_DAYS=30

# 1. Ejecutar backup del volumen Docker
cd /opt/goya-ledger
./scripts/sandbox-backup.sh "$BACKUP_DIR"

# 2. Verificar integridad del backup
LATEST=$(ls -t "$BACKUP_DIR"/cerulean-sandbox-*.tar.gz | head -1)
tar tzf "$LATEST" > /dev/null 2>&1 || {
    echo "ERROR: Backup corrupto: $LATEST" | mail -s "ALERTA: Backup Goya Ledger" seguridad@goya-ledger.cl
    exit 1
}

# 3. Copiar a ubicacion offsite
rsync -az "$LATEST" offsite-backup:/backups/goya-ledger/

# 4. Limpiar backups antiguos
find "$BACKUP_DIR" -name "cerulean-sandbox-*.tar.gz" -mtime + $RETENTION_DAYS -delete

# 5. Registrar en log de operaciones
echo "$(date -Iseconds) BACKUP OK: $(basename $LATEST)" >> /var/log/goya-backup.log
```

Backup de claves criptograficas

Las claves privadas del PSC se respaldan mediante procedimiento manual que requiere presencia de dos custodios:

1. Exportar claves en formato cifrado (AES-256-GCM).
2. Dividir la clave de cifrado mediante esquema Shamir Secret Sharing (2-de-3).
3. Entregar cada fragmento a un custodio diferente.
4. Almacenar en ubicaciones fisicas separadas (caja fuerte bancaria, HSM offsite).
5. Registrar la operacion en el registro de auditoria.

6.3 Procedimiento de restauracion

Restauracion completa desde backup

```
# 1. Detener el cluster
docker compose -f docker-compose.sandbox.yml down

# 2. Restaurar el volumen de datos desde tarball
./scripts/sandbox-backup.sh restore backups/cerulean-sandbox-
    YYYYMMDD-HHMMSS.tar.gz
# Este comando:
#   - Elimina el volumen existente (rust-bc_sandbox-data)
#   - Crea un volumen nuevo
#   - Extrae el tarball en el volumen

# 3. Reiniciar el cluster
./scripts/sandbox.sh

# 4. Verificar integridad post-restauracion
./scripts/bcctl.sh status
./scripts/e2e-test.sh
```

Restauracion del serial TSA

El serial de la TSA es un valor monotonicamente creciente que se persiste en disco. Tras una restauracion:

1. Verificar que el serial actual sea estrictamente mayor que el ultimo serial conocido antes de la falla.
2. Si el serial retrocedio (porque el backup es anterior al ultimo sellado emitido), avanzar manualmente el serial al valor seguro mas alto conocido + 1.
3. Documentar el salto de serial en el registro de auditoria.
4. Verificar que los sellos de tiempo emitidos post-restauracion sean validos.

Verificacion de integridad del registro de auditoria

```
# El registro de auditoria utiliza una cadena de hashes:
#   entry_hash = SHA-256(previous_hash || canonical_data)
# Donde canonical_data = timestamp|action|method|path|org_id|
#                       source_ip|status_code|trace_id|duration_ms
#
```

```

# La funcion verify_audit_chain() recorre todas las entradas
# y verifica que:
# 1. Cada entry_hash es correcto para sus datos
# 2. Cada previous_hash coincide con el entry_hash de la entrada
    anterior

# Invocar verificacion via API
curl -sk https://localhost:8080/api/v1/audit/verify

# Si la cadena esta rota, los registros anteriores al punto de
    rotura
# siguen siendo validos. Documentar la brecha y reiniciar la
    cadena
# desde el ultimo registro valido.

```

7. Plan de comunicaciones de crisis

7.1 Equipo de respuesta ante incidentes

Rol	Responsabilidad	Contacto
Director del PSC	Autoridad maxima. Activa Nivel 3. Comunica a entidad acreditadora.	Definir
Oficial de Seguridad	Coordina respuesta tecnica. Activa Nivel 2. Evalua impacto.	Definir
Administrador de Sistemas	Ejecuta procedimientos tecnicos de recuperacion. Activa Nivel 1.	Definir
Asesor Legal	Evalua obligaciones regulatorias de notificacion.	Definir
Responsable de Comunicaciones	Coordina notificaciones a suscriptores y partes confiantes.	Definir

7.2 Matriz de comunicacion

Destinatario	Cuando notificar	Plazo maximo	Medio	Contenido
Subsecretaria de Economia	Incidente Nivel 2 o 3	24 horas 48 horas	Oficio formal + correo electronico	Descripcion del incidente, impacto, acciones tomadas

Destinatario	Cuando notificar	Plazo maximo	Medio	Contenido
Suscriptores de certificados	Compromiso de claves o interrupcion > 4 horas		Correo electronico + publicacion web	Estado del servicio, acciones recomendadas
Partes confiantes	Cambio en estado de certificados	48 horas	Actualizacion CRL + OCSP	CRL actualizada, respuestas OCSP actualizadas
Equipo tecnico interno	Todo incidente	Inmediato	Canal de comunicacion de emergencia	Detalles tecnicos, procedimientos a ejecutar
Autoridad de proteccion de datos	Brecha de datos personales	72 horas (Ley 19.628)	Oficio formal	Datos afectados, medidas de mitigacion

7.3 Plantilla de notificacion a suscriptores

Asunto: [GOYA LEDGER PSC] Notificacion de incidente de servicio

Estimado(a) suscriptor(a):

Le informamos que el dia [FECHA] a las [HORA] (hora de Chile continental)
se detecto un incidente que afecta [DESCRIPCION DEL SERVICIO AFECTADO].

Estado actual: [EN PROCESO DE RECUPERACION / RESUELTO]

Impacto:

- [Descripcion del impacto en los servicios de certificacion]
- [Certificados afectados, si corresponde]

Acciones tomadas:

- [Listado de acciones de mitigacion y recuperacion]

Acciones recomendadas para el suscriptor:

- [Verificar estado de certificados via OCSP]
- [Otras acciones segun corresponda]

Proximo comunicado: [FECHA Y HORA]

Atentamente,

[Nombre]

Prestador de Servicios de Certificacion Goya Ledger

8. Pruebas y ejercicios

8.1 Calendario de pruebas

Tipo de prueba	Frecuencia	Participantes	Documentacion
Backup y restauracion	Mensual	Administrador de Sistemas	Registro de prueba firmado
Recuperacion de nodo individual (Nivel 1)	Trimestral	Equipo tecnico	Informe de prueba
Recuperacion de quorum (Nivel 2)	Semestral	Equipo tecnico + Oficial de Seguridad	Informe de prueba
Simulacro de desastre (Nivel 3)	Anual	Todo el equipo de respuesta	Informe ejecutivo
Prueba de comunicaciones de crisis	Semestral	Equipo de respuesta	Registro de tiempos
Verificacion de integridad de backups	Mensual	Administrador de Sistemas	Registro automatizado

8.2 Procedimiento de prueba de backup y restauracion

Prueba mensual de backup y restauracion

Ejecutar en entorno de pruebas, nunca en produccion

1. Crear backup del entorno de produccion

```
./scripts/sandbox-backup.sh /tmp/prueba-backup/
```

2. Levantar entorno de pruebas aislado

```
docker compose -f docker-compose.test.yml up -d
```

3. Restaurar backup en entorno de pruebas

```
./scripts/sandbox-backup.sh restore /tmp/prueba-backup/cerulean-sandbox-*.tar.gz
```

4. Ejecutar suite de pruebas completa

```
./scripts/e2e-test.sh # 71 aserciones E2E
```

```
./scripts/recovery-test.sh # Pruebas de recuperacion
```

5. Verificar integridad de cadena de bloques y registro de auditoria

6. Documentar resultados

7. Destruir entorno de pruebas

```
docker compose -f docker-compose.test.yml down -v
```

8.3 Criterios de exito

Cada prueba debe cumplir los siguientes criterios para considerarse exitosa:

- ☐ Tiempo de recuperacion dentro del RTO definido para el nivel correspondiente.
- ☐ Integridad de la cadena de bloques verificada (todos los hashes consistentes).
- ☐ Integridad del registro de auditoria verificada (cadena de hashes SHA-256 intacta).
- ☐ Serial TSA monotonicamente creciente post-restauracion.
- ☐ Servicios CA, TSA y OCSP operativos y respondiendo correctamente.
- ☐ Las 71 aserciones E2E de `scripts/e2e-test.sh` pasan satisfactoriamente.
- ☐ Los certificados emitidos antes del incidente siguen siendo verificables.
- ☐ Las firmas electronicas (FES y FEA) creadas antes del incidente siguen siendo validables.

8.4 Registro de pruebas

Cada prueba ejecutada debe generar un registro que contenga:

1. Fecha y hora de inicio y fin de la prueba.
 2. Tipo de prueba y nivel simulado.
 3. Participantes involucrados.
 4. Procedimientos ejecutados paso a paso.
 5. Resultados obtenidos frente a criterios de exito.
 6. Desviaciones o problemas encontrados.
 7. Acciones correctivas requeridas.
 8. Firma del responsable de la prueba.
 9. Firma del Oficial de Seguridad (para pruebas Nivel 2 y 3).
-

9. Mantenimiento y actualizacion del plan

9.1 Revision periodica

El presente Plan sera revisado y actualizado en las siguientes circunstancias:

- **Revision programada:** Semestralmente, en los meses de enero y julio.
- **Revision extraordinaria:** Dentro de los 30 dias siguientes a cualquiera de los siguientes eventos:
 - Ejecucion de un procedimiento de recuperacion real (no simulado).
 - Cambio significativo en la arquitectura del sistema.

- Cambio en la legislación o normativa aplicable.
- Resultado insatisfactorio en una prueba del Plan.
- Incorporación de nuevos servicios críticos.
- Cambio en el algoritmo de firma (por ejemplo, migración a nuevos esquemas post-cuánticos).

9.2 Control de cambios

Toda modificación al Plan debe seguir el siguiente procedimiento:

1. Identificación de la necesidad de cambio (revisión programada o evento gatillante).
2. Elaboración de la propuesta de modificación por el Oficial de Seguridad.
3. Revisión por el equipo técnico y el asesor legal.
4. Aprobación por el Director del PSC.
5. Actualización de la versión del documento y registro en la tabla de control de cambios.
6. Comunicación de los cambios a todo el personal involucrado.
7. Capacitación si los cambios afectan procedimientos operativos.

9.3 Tabla de control de cambios

Version	Fecha	Autor	Descripción del cambio	Aprobado por
1.0	Pendiente	Oficial de Seguridad	Version inicial del Plan	Pendiente

9.4 Distribución

El Plan se distribuye en los siguientes formatos y ubicaciones:

- **Repositorio de código:** docs/policy/PLAN-CONTINGENCIA.md (versión controlada en Git).
- **Copia impresa:** Oficina del Director del PSC y sala de servidores.
- **Copia digital offsite:** Almacenamiento cifrado en ubicación geográficamente separada.

Toda copia impresa o digital fuera del repositorio debe ser destruida al emitirse una nueva versión.

Anexo A: Lista de verificacion rapida

A.1 Verificacion diaria del operador

```
# Ejecutar cada dia por el administrador de sistemas
./scripts/bcctl.sh status # Estado del cluster
curl -sk https://localhost:8080/api/v1/health # Salud del nodo principal
```

A.2 Verificacion post-incidente

- ☐ Todos los nodos reportan estado saludable (bcctl.sh status).
- ☐ Consenso BFT activo y produciendo bloques.
- ☐ Serial TSA monotonicamente creciente.
- ☐ Cadena de hashes del registro de auditoria intacta.
- ☐ Servicios CA, TSA y OCSP responden correctamente.
- ☐ Suite E2E completa (71 aserciones) pasa sin errores.
- ☐ Backups programados ejecutandose correctamente.
- ☐ Incidente documentado en el registro de auditoria.

A.3 Contactos de emergencia

Rol	Nombre	Telefono	Correo
Director del PSC	Por definir	—	—
Oficial de Seguridad	Por definir	—	—
Administrador de Sistemas	Por definir	—	—
Asesor Legal	Por definir	—	—
Soporte Infraestructura Cloud	Por definir	—	—

Anexo B: Glosario

Termino	Definicion
BFT	Byzantine Fault Tolerance. Tolerancia a fallas bizantinas en el protocolo de consenso.

Termino	Definicion
BIA	Business Impact Analysis. Analisis de impacto al negocio.
CA	Certificate Authority. Autoridad de Certificacion.
CRL	Certificate Revocation List. Lista de revocacion de certificados.
DPoS	Delegated Proof of Stake. Mecanismo de seleccion de validadores por delegacion.
DRP	Disaster Recovery Plan. Plan de recuperacion ante desastres.
FEA	Firma Electronica Avanzada (Ley 19.799, art. 2 letra g).
FES	Firma Electronica Simple (Ley 19.799, art. 2 letra f).
HSM	Hardware Security Module. Modulo de seguridad por hardware para custodia de claves.
OCSP	Online Certificate Status Protocol. Protocolo de consulta de estado de certificados en linea.
PSC	Prestador de Servicios de Certificacion (Ley 19.799).
RPO	Recovery Point Objective. Punto de recuperacion objetivo (perdida de datos maxima tolerada).
RTO	Recovery Time Objective. Tiempo de recuperacion objetivo.
TSA	Time Stamping Authority. Autoridad de Sellado de Tiempo (RFC 3161).
WAL	Write-Ahead Log. Registro de escritura anticipada de RocksDB.